

SCG Review - Gemini Enterprise for CX

Executive Summary

Reviewed `_src/geminiCustomerExperienceGuidance.csv` at deep depth with a HIPAA and HITRUST CSF v11 overlay: 138 requirements across 12 categories, IDs 10 to 1380, as updated earlier today. The request named `geCustomerExperienceGuidance.csv`, which does not exist; it is the `csvFile` value in the archived draft's `DocGen.json`, and the author confirmed the current guide. Structurally the guide is clean: canonical 17-column header, unique IDs on multiples of ten, all eight downstream columns empty, pure ASCII, no embedded newlines, one bolded directive per requirement, and no cross-references to other rows or guides. All 71 distinct NIST SP 800-53 identifiers exist in the Rev. 5 OSCAL catalog with no withdrawn control and no title mismatch, and all 46 reference URLs returned HTTP 200 with on-topic page titles. Every row was then checked against the vendor pages by three independent reviewers working from fresh context, with the highest-impact claims re-verified against the live pages before inclusion. **Counts: 0 Blocker, 49 Major, 60 Minor, 20 Info. Verdict: fix the Majors, then publish.** No finding makes the guide unsafe to feed downstream tooling, but three groups of Majors would cause real control failures if implemented as written. First, several rows name the wrong audit log type, so the alerts they require would never fire. Second, the IAM rows miss role inheritance that Google documents: every agent builder can read the entire CX Insights conversation corpus, and members on the recommended OAuth path would hold `tools.execute`. Third, the service perimeter omits the Agent Assist API. The earlier reviews missed most of these because they checked what the guide cites; this review also read the pages the guide does not cite, such as the audit-method tables, role definitions, and settings pages. Today's update introduced four of the defects directly: the filter-default wording at ID 390, the Transcribe Live characterization at ID 770, the missing SA-9 parent at ID 1350, and the missing HIPAA segment on new ID 1360. Its HITRUST pass also left IDs 50, 410, 450, and 490 without a segment that this review judges applicable. Separately, one Major (ID 630) is a 2026-09-04 remediation that was applied to the Notes but not the Rationale.

Counts

Severity	Count
Blocker	0
Major	49
Minor	60
Info	20

Requirements per category:

Category	Rows
General	9
Identity & Access Management	13
Agents & Agent Management	12
AI Models & Model Management	4
Tools & External Integrations	21
Deployment & Channel Security	12

Category	Rows
Agent Assist & Human Agent Support	11
Conversation Analytics & Insights	14
Data Protection & Privacy	13
Network & Perimeter Security	10
Monitoring & Analytics	11
Compliance & Certification	8

Findings covering several rows are recorded once, with every affected ID listed. One reviewer grade was changed on adjudication: the SecureCo omission at ID 500 was lowered from Major to Minor, because the requirement is unaffected and only its illustrative list is incomplete.

Findings

#	Se ve rit y	Row ID	Category	Finding	Recommendation
1	Ma jor	150	Identity & Access Management	Notes state "Deployment actions appear in Admin Activity audit logs and should be alerted on." Google's CX Agent Studio audit table lists CreateDeployment, UpdateDeployment, and DeleteDeployment under DATA_WRITE, which produces Data Access logs that are off by default. An alert built on Admin Activity will never fire.	State that deployment actions are Data Access (DATA_WRITE) events and require Data Access logging on <code>ces.googleapis.com</code> .
2	Ma jor	570	Deployment & Channel Security	Two claims are contradicted. "Split configuration changes appear in Admin Activity audit logs" - UpdateDeployment is DATA_WRITE (Data Access). "Traffic splitting became generally available on July 1, 2026" - the release note says only "You can now use traffic splitting" and the traffic-split page configures it through v1beta. Google also presents splitting as a way to "safely deploy updates in stages", contrary to "an experimentation control rather than a release control".	Drop the GA claim or cite a GA source, correct the log type, and align the release-control characterization with the vendor page.
3	Ma jor	1050	Network & Perimeter Security	Notes state "Admin Activity audit logs record import and export." Google lists <code>AgentService.ExportApp (LR0)</code> under ADMIN_READ, a Data Access sub-type; only <code>ImportApp</code> is ADMIN_WRITE. Export is the exfiltration-relevant operation and is invisible unless ADMIN_READ is enabled.	State that <code>ExportApp</code> is recorded only in Data Access (ADMIN_READ) logs and require that sub-type.
4	Ma jor	1080	Monitoring & Analytics	Notes state "The DATA_READ tier covers conversation analysis, model management, rule creation, feedback labeling, and assessment operations." Google's CX Insights audit table places <code>CreateAnalysis</code> , <code>CreateAnalysisRule</code> , <code>BulkDeleteConversations</code> , and <code>UpdateSettings</code> under DATA_WRITE. Following the Notes leaves almost every Insights mutation, including bulk delete, unlogged.	Require ADMIN_READ, DATA_READ, and DATA_WRITE for <code>contactcenterinsights.googleapis.com</code> and correct the Notes.
5	Ma jor	160	Identity & Access Management	The requirement and Notes assert "Human users and broad groups are never appropriate holders of this role" and "the two lists should match exactly." Google's access-control page lists <code>ces.googleapis.com/client</code> as a base role of <code>admin</code> , <code>agentEditor</code> , <code>toolsEditor</code> , <code>guardrailsEditor</code> , and <code>evalsEditor</code> , and the OAuth2 web-widget path requires end-user credentials to reach the agent. The reconciliation cannot pass as written.	Scope the rule to direct <code>ces.googleapis.com/client</code> bindings on non-human principals, and name OAuth end-user access as a separately approved channel.

#	Se ve rit y	Row ID	Category	Finding	Recommendation
6	Ma jor	530	Deployment & Channel Security	Requires "the OAuth2 client end-user authentication path rather than a service-account token broker." On that path the member's identity must hold access to the agent, i.e. the client role, whose permissions include <code>ces.googleapis.com/tools.execute</code> . An authenticated member could then call tools directly, outside the agent, with the tools' configured identity. The row also excludes Google's custom authentication API option, which fits an organization-operated member identity provider.	Require per-member authentication through the organization's identity provider (OAuth2 or a custom auth API issuing a session-scoped token), and state that member identities MUST NOT hold any role that includes <code>tools.execute</code> .
7	Ma jor	530, 540	Deployment & Channel Security	Rows contradict each other. 530 forbids a service-account broker for authenticated members; 540 says "A self-hosted token broker SHOULD be used ... for any agent application handling member interactions," and a self-hosted broker is a service-account broker.	Limit 540 to unauthenticated or bounded-public agents, or restate both rows as one decision table in their Notes.
8	Ma jor	500	Deployment & Channel Security	Notes instruct the reader to "reconcile exactly against the holders of the query-access client role, because every channel needs one and nothing else legitimately does." The client role is inherited by every CES editor role and held by OAuth end users, so the reconciliation fails by design.	Reconcile against direct grants of <code>ces.googleapis.com/client</code> to non-human principals only.
9	Ma jor	730	Conversation Analytics & Insights	The requirement restricts direct grants of <code>roles/contactcenterinsights.viewer</code> and <code>editor</code> . Google's access-control page shows <code>ces.googleapis.com/viewer</code> ("Base roles: <code>contactcenterinsights.googleapis.com/viewer</code> "), which is itself the base of every CES editor role, and <code>ces.googleapis.com/admin</code> includes <code>contactcenterinsights.googleapis.com/admin</code> . Every agent builder can therefore read the whole conversation corpus while the row reports the access as restricted.	Extend the requirement to every principal holding <code>contactcenterinsights.*</code> directly or through any <code>ces.googleapis.com/*</code> role, and name the Insights admin role.
1 0	Ma jor	970	Network & Perimeter Security	Rationale states "These two API services are the entire data plane of the suite." Google's VPC Service Controls supported-products page lists Agent Assist under service name <code>dialogflow.googleapis.com</code> , and the CX Insights entry adds "To integrate multiple CCAI products, add the Agent Platform API to your service perimeter." A perimeter built from this row leaves Agent Assist unrestricted.	Add <code>dialogflow.googleapis.com</code> , and the Agent Platform API where products are integrated, to the restricted services, and remove "entire data plane".
1 1	Ma jor	1200	Compliance & Certification	"Google Cloud surfaces branded Dialogflow MUST NOT be used to process protected health information" cannot be satisfied while using covered Agent Assist, whose API is <code>dialogflow.googleapis.com</code> , and CX Insights states "To integrate conversation data ... from Dialogflow and Agent Assist you must enable Dialogflow runtime integration." Google's Dialogflow CX documentation also describes the Conversational Agents console as replacing the Dialogflow CX console, so the naming premise is doubtful.	Restate as a requirement that every API in the data path be confirmed by Google in writing as within a covered product, with the Dialogflow API used by Agent Assist and Conversational Agents named explicitly.
1 2	Ma jor	1000	Network & Perimeter Security	The row relies on a process allowlist and never mentions the product's native, enforceable one. Google's settings page: "Allowed origins ... This applies to all types of tools and callbacks ... If VPC Service Controls are enabled, no endpoint is allowed unless it is added to the allowed origins list." The <code>REST EndpointControlPolicy</code> supports an enforcement scope that applies regardless of VPC-SC status. The phrase "without Service Directory configuration" does not appear on the cited VPC-SC page.	Require the allowed-origins endpoint control policy with an always-enforced scope, and cite the settings and <code>SecuritySettings</code> REST pages.
1 3	Ma jor	1120	Monitoring & Analytics	Rationale states "Security settings are project-wide and govern redaction, retention, and export behaviour." The <code>SecuritySettings</code> resource carries only the endpoint control policy; redaction, Cloud Logging, BigQuery export, audio recording, and interaction data are agent application settings changed through <code>UpdateApp</code> . The alert as written misses changes to logging and redaction.	Rewrite the rationale around the egress allowlist and extend the alert to <code>AgentService.UpdateApp</code> .

#	Se ve rit y	Row ID	Category	Finding	Recommendation
14	Major	1310	Tools & External Integrations	Rationale premise "Every tool call reaches the backend as the single CX Agent Studio service agent" is contradicted: OpenAPI and MCP tools support a customer service account, OAuth, and API keys, and connector tools support end-user credential pass-through. The control remains sound; its stated basis is not.	Reword to "tool calls commonly reach the backend under a shared platform or tool identity", and cite the documented <code>x-ces-session-context</code> parameter and MCP session-context headers as the mechanism.
15	Major	10	General	Rationale states the Pre-GA Offerings Terms say pre-GA offerings "are not necessarily covered by the compliance certifications (HIPAA, SOC 2, ISO 27001, FedRAMP)". The terms contain no such statement. They do say, more strongly, that the Data Location section does not apply and "Customer should not use Pre-GA Offerings to process personal data or other data subject to legal or regulatory compliance requirements", and Google's HIPAA page says "Do not use Pre-GA offerings ... in connection with PHI".	Replace the certification sentence with those two quotes and add the HIPAA compliance page to References.
16	Major	20	General	Rationale rests on "no entry in the HIPAA covered products list." The list carries the umbrella entry "Gemini Enterprise for Customer Experience (GECX)", so the premise is unsound.	Rest the prohibition on the unreleased status ("Commerce agents coming soon.") and Google's Pre-GA/PHI statement.
17	Major	60	General	Rationale includes "the conversation TTL" among decisions that "close permanently at or before first use" and cites only the suite overview and HIPAA pages. The TTL page shows TTL can be set per conversation and project-wide, and conversations can always be deleted. CMEK irreversibility is correct.	Remove TTL from the irreversible list and cite the CX Agent Studio CMEK, CX Insights CMEK, and region pages.
18	Major	250	Agents & Agent Management	Notes: "An exact response or a handoff to a human is a safe terminal state." The guardrail outcome is "Handoff to an agent: Transition control to a specific agent" - another CX Agent Studio agent, not a person. Human escalation is performed with the <code>end_session</code> system tool.	Specify "Say exactly" or a handoff to an agent whose only behaviour is <code>end_session</code> with escalation.
19	Major	310	Agents & Agent Management	Repeats the handoff misreading ("the Prompt guard offers agent handoff as a triggered outcome") and asserts "Disclosure of automated interaction is a growing statutory obligation across US states" without a source. Mappings (164.520, PT-4, AC-3, 06.d) do not fit an automated-interaction disclosure.	Cite the system tool page for escalation and a specific statute, and keep PT-5 as the mapping spine.
20	Major	300	Agents & Agent Management	Rationale: "this suite provides no mechanism that distinguishes a grounded answer from a plausible one at the point of delivery." The data store tool exposes a grounding-score threshold. Mappings (164.502(a), 164.520, SI-10, AC-3, PT-2) do not describe human decision oversight.	Say no mechanism reliably prevents an ungrounded determination, and remap to decision-oversight controls (for example NIST AI RMF MANAGE) with the relevant claims-procedure regulation.
21	Major	440	Tools & External Integrations	Scope names "Integration Connector tools for Salesforce, ServiceNow, Jira, Confluence, and SharePoint"; the dedicated Salesforce, ServiceNow, and Jira tools are OpenAPI-based tool types ("Authentication: See OpenAPI tool API authentication"), so the requirement does not cover them. "Because retrieval through the tool is not user-scoped" is contradicted by the connector tool's credential pass-through.	Scope the row to both the dedicated tools and Integration Connector tools, and name end-user authentication override as the preferred option.
22	Major	480	Tools & External Integrations	"OpenAPI tools MUST NOT target endpoints reachable only over the public internet where a private path through Service Directory is available" is self-contradictory: an endpoint reachable only publicly has no private path. Untestable.	Reword: where a backend is reachable through Service Directory, OpenAPI, MCP, and SaaS tools MUST use it.

#	Se ve rit y	Row ID	Category	Finding	Recommendation
23	Major	130, 180	Identity & Access Management	References do not support the rows. 130's rationale rests on basic-role behaviour and 180 names an organization policy constraint, but neither cited page covers basic roles, service account keys, or the key-creation constraint.	Cite the IAM basic-roles documentation (130) and the service-account-key best practices with <code>iam.disableServiceAccountKeyCreation</code> (180).
24	Major	40	General	Near-identical Pre-GA prohibitions are calibrated differently: a Preview tool is Med here while a Preview model (1270) and the baseline (10) are High, and 40's own rationale says data leaves the boundary.	Raise 40 to High or record why a Preview tool carries less risk than a Preview model.
25	Major	1320, 1350	Agent Assist & Human Agent Support	Near-identical Preview-feature prohibitions on live member conversations: 1320 is Med, 1350 is High. Google's HIPAA page prohibits Pre-GA use with PHI regardless of the global remap on which 1350 relies.	Rate 1320 High.
26	Major	630	Agent Assist & Human Agent Support	Rationale still reads "retained for a configurable period defaulting to one year with a two-year maximum". Those figures belong to the CX Agent Studio conversation-history page; Agent Assist states "The default and maximum retention window is 30 days." The 2026-09-04 remediation corrected the Notes but not the Rationale, so the row now contradicts itself. The Notes also contradict each other ("scope the longer period" versus a need beyond 30 days "cannot be met by changing this setting").	Rewrite the Rationale around the 30-day ceiling and delete the contradictory Notes sentence.
27	Major	630, 710	Agent Assist & Human Agent Support; Conversation Analytics & Insights	Retention controls over the same class of data are calibrated differently: Agent Assist retention is Med, CX Insights TTL is High.	Align the ratings or state the exposure difference.
28	Major	620, 720, 920	Agent Assist & Human Agent Support; Conversation Analytics & Insights; Data Protection & Privacy	Redaction rows cite "164.514(a) (De-identification of PHI)" and "SI-18 (Personally Identifiable Information Quality Operations)" (620 and 720 also cite SI-10). Sensitive Data Protection redaction of free-form conversation does not meet Safe Harbor or Expert Determination, so the citation invites treating redacted transcripts as non-PHI. SI-18 is PII accuracy, not redaction.	Replace 164.514(a) with 164.502(b) and SI-18/SI-10 with SI-19 (De-identification).
29	Major	640, 650, 660, 670	Agent Assist & Human Agent Support	References do not support these High rows. The <code>agent-assist</code> root page is a landing page; <code>data-redaction-retention</code> , <code>cx-agent-studio/tool/data-store</code> , and <code>insights/common-integrations</code> do not cover summarization, Smart Reply sending, Knowledge Assist scoping, or live translation.	Cite the Agent Assist summarization, Smart Reply, generative knowledge assist and KA filters, and live A2A translation pages.
30	Major	660	Agent Assist & Human Agent Support	"there is no per-representative filtering of what the retrieval can return" is contradicted: Knowledge Assist supports per-query document filters ("Filter knowledge assist documents for both GKA and PGKA with SearchConfig"). The filters are client-supplied rather than IAM-enforced, so corpus scoping remains the right control.	State that metadata filters exist but are not an authorization boundary.
31	Major	680	Agent Assist & Human Agent Support	Omits residency exceptions on the cited page that matter for PHI: "Model training does not support regionalization. Your data may get routed outside the region during this process"; "The Agent Assist console doesn't support regionalization"; generative knowledge assist data stores limited to global, us, or eu. The Notes are internally inconsistent ("Three documented limitations ... both limitations").	List every documented exception, require API-only regional configuration, and fix the count.

#	Se ve rit y	Row ID	Category	Finding	Recommendation
3 2	Ma jor	740	Conversation Analytics & Insights	Assumes authorized views are in use ("Where authorized views are used for evaluation purposes") without noting they are Pre-GA; Google's HIPAA page says "Do not use Pre-GA offerings ... in connection with PHI".	Permit authorized views only on synthetic or non-PHI data until GA, and define "evaluation purposes".
3 3	Ma jor	800	Conversation Analytics & Insights	Rated Med, but the Google Sheets integration is itself Pre-GA and moves data into Workspace, outside the Google Cloud product set in the BAA; the BigQuery export (780) is High. The Notes still permit aggregates in Sheets.	Raise to High, cite the Pre-GA status, and prohibit the integration in PHI projects.
3 4	Ma jor	590	Deployment & Channel Security	"the product provides no rate limiting, quota policy, request logging, or payload inspection of its own at that boundary" is contradicted: CX Agent Studio has project-level quotas, RunSession is audit-logged, and guardrails inspect content.	State that native controls are project-scoped rather than per-caller, and justify the gateway on per-caller throttling and authorization.
3 5	Ma jor	600	Deployment & Channel Security	"Every voice deployment path in this suite results in call audio being captured ... retained in Cloud Storage" is contradicted: audio storage is opt-in customer-owned storage. The legal basis for recording consent is state wiretap law, which is uncited, and 164.520 (Notice of Privacy Practices) does not ground it.	Reword to "where audio recording or Insights ingestion is enabled", cite a state-law source, and drop or justify 164.520.
3 6	Ma jor	910	Data Protection & Privacy	Rationale: "That statement is scoped to one toggle on one page of one component." The cited Service Specific Terms contain a contractual restriction in section 18: "Google will not use Customer Data to train or fine-tune any AI/ML models without Customer's prior permission or instruction."	Cite section 18 as the contractual basis and require written confirmation that it covers each GECX component and data path.
3 7	Ma jor	960	Data Protection & Privacy	Rationale: "the control available is not prevention but a record of when it occurred." Access Approval, a preventive approval gate on Google personnel access, lists Customer Experience Agent Studio, Customer Experience Insights, and Gemini Enterprise for Customer Experience as GA.	Add Access Approval as the preventive control, keep Access Transparency as the record, and cite both supported-services pages.
3 8	Ma jor	1100	Monitoring & Analytics	Notes paraphrase "HIPAA 164.316(b)(2) requires documentation, including records of access to protected health information, to be retained for six years". 164.316(b)(2)(i) requires retaining the documentation required by (b)(1) - policies, procedures, and records of required actions - and does not mention PHI access records. "Cloud Logging's default retention is shorter" is not supported by a cited page.	Present six years as the organization's interpretation that audit logs are (b)(1) records, and cite Cloud Logging retention documentation.
3 9	Ma jor	940	Data Protection & Privacy	Cites "164.526 (Amendment of PHI)" as a basis for deletion; HIPAA creates no deletion right, and the BAA states Google does not maintain PHI in a designated record set. The rationale's "deletion obligation" names no source. AU-11 does not fit (conversation data is not audit records).	Drop 164.526 and AU-11, and name the actual deletion driver (retention schedule, state law, or the BAA return-or-destroy clause).
4 0	Ma jor	1060, 1120	Network & Perimeter Security; Monitoring & Analytics	Near-identical alert-on-protective-control-change rows: perimeter changes (1060) Med, security-settings changes (1120) High, although 1060 calls the perimeter "the compensating control for several exposures this product cannot address internally".	Rate 1060 High or record why.
4 1	Ma jor	1080, 1150	Monitoring & Analytics	Enabling the Insights Data Access log is a High MUST (1080) but monitoring it is Med SHOULD (1150), while 1150 says "detection is the available control" and 1080 calls the log "the primary compensating control".	Raise 1150 to High and MUST.
4 2	Ma jor	1020, 1040, 1050	Network & Perimeter Security	1050 (import/export buckets inside the perimeter, Med) is a subset of 1020 (all referenced buckets inside the perimeter, High); 1040 (agent references inside the perimeter) is also Med.	Align ratings or merge 1050 into 1020.

#	Severity	Row ID	Category	Finding	Recommendation
43	Major	990	Network & Perimeter Security	The only cited page does not mention dry-run mode, the subject of this High row.	Cite the VPC Service Controls dry-run documentation.
44	Major	50, 490	General; Tools & External Integrations	HITRUST CSF v11 missing on access-control rows: 50 governs the only per-conversation access boundary (AC-3 mapped); 490 limits the service agent's effective privilege (AC-6 mapped), where the equivalent 170 carries 01.c.	Add 01.v (50) and 01.c (490).
45	Major	410, 450	Tools & External Integrations	HIPAA and HITRUST CSF v11 both missing on PHI-surface rows: 410 is an authorization control on the confused-deputy path to PHI; 450's Python code can read the entire conversation and reach only the public internet.	Add 164.312(a)(1) and 01.v (410); 164.312(e)(1) and 09.s (450).
46	Major	500, 550	Deployment & Channel Security	HITRUST CSF v11 missing on rows that govern who can reach the agent; 550 also lacks HIPAA although its rationale says member data "transits a page the organization does not control".	Add 01.j or 01.v to both and 164.312(a)(1) to 550.
47	Major	950	Data Protection & Privacy	No HIPAA or HITRUST although the row documents stores holding conversation data; the near-identical 1220 carries 164.316(b)(1) and 06.d.	Add 164.316(b)(1) and 06.d.
48	Major	430, 870, 880, 1040, 1360	Tools & External Integrations; Data Protection & Privacy; Network & Perimeter Security	HIPAA missing on rows governing where PHI-bearing content is stored or sent: MCP hosting (430), residency (870, 880), cross-perimeter agent references (1040), and the File search knowledge-base location (1360). Sibling perimeter rows cite 164.312(e)(1) or 164.312(a)(1).	Add the fitting Security Rule citation, or 164.308(a)(1)(ii)(B) for the residency decisions, or state that HIPAA does not apply.
49	Major	270, 370	Agents & Agent Management; Tools & External Integrations	"164.312(a)(2)(i) (Unique User Identification)" does not fit a secrets-hygiene control.	Use 164.312(a)(1) and/or 164.312(d).
50	Minor	500	Deployment & Channel Security	"publishes an agent to seven distinct surfaces" omits SecureCo, which the deploy page lists as an eighth. Adjudicated from Major to Minor: the requirement (maintain an inventory) is unaffected; only the illustrative list is incomplete.	Name SecureCo or avoid a fixed count.
51	Minor	770	Conversation Analytics & Insights	Two issues. The 2026-09-23 Note "Agent Assist transcription is not always performed by Cloud Speech-to-Text" misreads the vendor page, which describes Gemini Transcribe Live as choosing "the Gemini model for Speech-to-Text API" - a model option within Speech-to-Text, not another service. SC-8 and 164.312(e)(1) are transmission citations on an at-rest CMEK row.	Correct the Note to describe a Speech-to-Text model choice, and replace SC-8 with SC-28(1).
52	Minor	1350	Agent Assist & Human Agent Support	SA-9(5) is cited without its parent SA-9 (introduced 2026-09-23).	Add SA-9 (External System Services).
53	Minor	390	Tools & External Integrations	Notes present one side of a vendor inconsistency: the console page states "Never (Default)" for the filter parameter while the REST enum default includes it for connector data stores; the console label is "Always", not "Always include" (introduced 2026-09-23).	Note the conflict and keep the conclusion that the filter is not an access control.
54	Minor	1270	AI Models & Model Management	Same misattribution as ID 10: "not necessarily inside the compliance certifications" is not in the Pre-GA terms.	Use the section 5(d) and HIPAA-page quotes.
55	Minor	70	General	"ten capability additions in the eleven months following general availability": GA was 2026-02-04 (about 7.5 months ago) and the notes show 12 feature entries. "Features arrive enabled and visible	Restate with a checked count and date range; source or drop the opt-in claim.

#	Severity	Row ID	Category	Finding	Recommendation
	r			in the console rather than behind an opt-in" is unsourced.	
56	Minor	110	Identity & Access Management	Notes name "the admin, securitySettingsEditor, and deploymentEditor roles" as the three that can change security posture; guardrailsEditor and toolsEditor can as well.	Add both roles.
57	Minor	260	Agents & Agent Management	"The Blocklist is the only guardrail that encodes organization-specific language" - the Rules guardrail can too.	Say "the only term-matching guardrail".
58	Minor	330, 350, 420, 90	General; Agents & Agent Management; Tools & External Integrations	Reach is overstated. Tools are per-application resources with per-tool credentials; an agent-as-tool targets an agent in the same application with its own tool set; MCP tools may use per-tool identities. 90 teaches "tools run as the platform identity, retrieval is not permission-aware" as unqualified fact.	Reword to the service agent's grants plus tool-level identities, and hedge 90 consistently.
59	Minor	120, 340, 670	Identity & Access Management; Agents & Agent Management; Agent Assist & Human Agent Support	Notes repeat the Rationale or themselves (for example 670: "Retain source-language transcript alongside the translation and mark translated turns" appears twice).	Delete the duplicates.
60	Minor	320	Agents & Agent Management	Notes call a review mandate "the prohibition".	Say "requirement".
61	Minor	240	Agents & Agent Management	Requirement allows Balanced on any agent that can reach member data; Notes limit Balanced to internal-facing agents. Two readings.	Require Strict for member-facing agents or drop the Notes restriction.
62	Minor	250, 400	Agents & Agent Management; Tools & External Integrations	SI-3 (Malicious Code Protection) is a stretch for prompt injection.	Drop SI-3.
63	Minor	460	Tools & External Integrations	SC-8 (Transmission Confidentiality and Integrity) does not fit a disclosure-to-client risk (carried into the 2026-09-23 revision).	Drop SC-8.
64	Minor	100	Identity & Access Management	IA-8 (Non-organizational Users) cited for administrators and builders.	Drop IA-8.
65	Minor	170, 350	Identity & Access Management; Tools & External Integrations	OWASP API5 (Broken Function Level Authorization) is a stretch for service-agent IAM and project boundaries.	Keep ASI03 and drop API5.
66	Minor	170, 300, 330, 350, 380, 400, 410, 420,	Identity & Access Management; Agents & Agent Management;	Edition label "OWASP Agentic Top 10 2025" - the published title is "OWASP Top 10 for Agentic Applications for 2026" (released 2025-12-09). IDs and titles are correct.	Relabel the edition.

#	Severity	Row ID	Category	Finding	Recommendation
		450, 490, 1310, 1330	Tools & External Integrations		
67	Minor	100, 110, 200	Identity & Access Management	References (access-control, agent-assist, common-integrations) do not discuss federation, MFA, or representative authentication.	Cite workforce identity federation and Cloud Identity SSO/2SV documentation.
68	Minor	150	Identity & Access Management	The cited deploy page does not mention traffic splitting.	Cite the traffic-splitting page or the release note.
69	Minor	540	Deployment & Channel Security	"offers no place to apply an organization-specific condition before a token is minted" - origin and reCAPTCHA checks exist.	Say "no organization-defined logic beyond origin and reCAPTCHA".
70	Minor	550	Deployment & Channel Security	"Enforce with the widget's origin check" names a control of the Google-hosted public broker that 510 forbids for member-data agents.	Name the origin control per authentication mode (OAuth authorized JavaScript origins, or broker-side validation).
71	Minor	560	Deployment & Channel Security	The central service-agent claim is supported by <code>tool/open-api</code> , which the row does not cite.	Add it.
72	Minor	1300	Deployment & Channel Security	"Set caps per deployment rather than per project" cannot be implemented; quotas are per project, region, and base model, and no cited page covers quotas.	Isolate high-risk channels in separate projects and cite the quotas page.
73	Minor	610, 700	Agent Assist & Human Agent Support; Conversation Analytics & Insights	164.312(e)(2)(ii) is transmission encryption on at-rest CMEK rows.	Remove it.
74	Minor	620	Agent Assist & Human Agent Support	The perimeter redaction-failure limitation is documented for CX Agent Studio, not Agent Assist; "created once per project and location" overstates "You can configure separate security settings for each project and location"; <code>insights/common-integrations</code> does not support the row.	Attribute correctly and drop the weak reference.
75	Minor	640	Agent Assist & Human Agent Support	Notes allow what the requirement forbids: "Where summaries are written automatically with no human step, they must be labelled as machine-generated."	Remove, or make it an explicit approved exception.
76	Minor	640, 670	Agent Assist & Human Agent Support	164.502(a) does not fit output-integrity rows.	Keep 164.312(c)(1) only.
77	Minor	640, 650, 670	Agent Assist & Human Agent Support	HITRUST CSF v11 absent on PHI-surface output rows (650 transmits content to members).	Add 06.d (650) and 06.c (640, 670), or record why out of scope.
78	Minor	670	Agent Assist & Human Agent Support	The product feature is live audio-to-audio translation (private GA, limited access), not translated text output.	Describe the feature accurately.

#	Se ve rit y	Row ID	Category	Finding	Recommendation
	r				
79	Minor	690	Agent Assist & Human Agent Support	"AI Coach delivers real-time guidance and coaching, and the analytics layer generates assessments of representative performance" - AI coach suggests responses; it does not evaluate performance.	Anchor on Quality AI scoring or merge with 820.
80	Minor	710	Conversation Analytics & Insights	"can only be removed by locating and deleting each one individually" - CX Insights has BulkDeleteConversations.	Say conversations must be enumerated and deleted explicitly, for example by bulk delete with a filter.
81	Minor	720	Conversation Analytics & Insights	RedactionConfig is real but no cited page documents it.	Cite the RedactionConfig reference.
82	Minor	760	Conversation Analytics & Insights	The audio-write limitation is the CX Agent Studio VPC-SC limitation and applies only with VPC-SC; bucket CMEK cites no Cloud Storage source.	Qualify and cite Cloud Storage CMEK documentation.
83	Minor	1320	Agent Assist & Human Agent Support	"Agent Assist has moved several capabilities to general availability without a corresponding change in the feature table" is unsupported.	Remove or cite an instance.
84	Minor	630, 710, 760, 780, 800, 830, 1100	Agent Assist & Human Agent Support; Conversation Analytics & Insights; Monitoring & Analytics	"164.530(j) (Documentation)" requires retaining HIPAA documentation, not retaining or deleting PHI or audit records.	Drop it, or cite it only for documenting the retention decision.
85	Minor	840	Data Protection & Privacy	"the only remedy is a new project with everything rebuilt in it" - the vendor recommends resources "be exported and restored in a new project".	Say "exported and restored".
86	Minor	850	Data Protection & Privacy	CP-9 (System Backup) does not fit gating key destruction; the monitoring half lacks HITRUST 09.ab.	Replace CP-9 (SC-12 with CM-5) and add 09.ab.
87	Minor	860	Data Protection & Privacy	" MUST account for the vendor's statement" is untestable; the Insights CMEK page does not contain the no-re-encryption statement; the row is Med while 850, with the same data-loss outcome, is High.	Reword as a MUST NOT on disabling or destroying key versions that protect retained data, cite only the CX Agent Studio CMEK page, and align the rating.
88	Minor	870, 880	Data Protection & Privacy	SC-7 and AC-4 fit poorly for residency; AU-4 fits poorly for log residency; "relocates member conversation content" is inferred.	Trim the mappings and soften the claim to "may contain".
89	Minor	890	Data Protection & Privacy	164.502(b) and AU-11 fit poorly; Notes say the setting "governs the CX Agent Studio conversation store only" but the vendor states "This applies to both CX Agent Studio and CX Insights".	Correct the scope and trim the mappings.

#	Severity	Row ID	Category	Finding	Recommendation
900	Minor	900	Data Protection & Privacy	AU-2 fits poorly; the toggle governs storage of conversation data, not audit events.	Replace with SI-12 and CM-6.
911	Minor	930	Data Protection & Privacy	SI-18 fits poorly; no HITRUST 01.v; Google's HIPAA page directly supports the row ("avoid including PHI or security credentials anywhere in your agent definition") but is not cited.	Cite the HIPAA page, add 01.v, and reconsider High.
922	Minor	960	Data Protection & Privacy	"Where Google support access ... is a concern" is an untestable condition; for a PHI corpus it is always met.	Make the directive unconditional.
933	Minor	970	Network & Perimeter Security	Notes name Cloud KMS and Speech-to-Text as documented breakage points; the cited page names Storage, BigQuery, DLP templates, secrets, and data stores.	Correct the list.
944	Minor	980, 1120	Network & Perimeter Security; Monitoring & Analytics	Unsupported absolutes: "a permanent hole that nobody revisits"; "the highest-value single signal available in this deployment".	Remove.
955	Minor	990	Network & Perimeter Security	Notes say redaction occurs only on batch or asynchronous operations; redaction is applied per conversation before storage.	Correct.
966	Minor	1000	Network & Perimeter Security	"configurable by any holder of the tools editor role" - callbacks are changed through the Agent Editor role; "arbitrary" is undefined.	Name both roles and define "arbitrary" as not on the allowed-origins list.
977	Minor	1010	Network & Perimeter Security	"It is the only mechanism that lets a tool reach an internal system" - Integration Connectors are also documented.	Remove "only".
988	Minor	1030	Network & Perimeter Security	" MUST be deny by default" is always true of a VPC-SC perimeter; the cited page does not cover ingress/egress rules or allowed origins; Med conflicts with the rationale's claim that a perimeter's value is its exception list.	Restate as a prohibition on broad ingress/egress rules with documented owners, cite the ingress/egress documentation, and align the rating with 980 and 990.
999	Minor	1060	Network & Perimeter Security	The VPC-SC product page does not cover Access Context Manager change alerting.	Cite Access Context Manager audit logging.
1000	Minor	1070, 1080	Monitoring & Analytics	"Data Access audit logs MUST be explicitly enabled" does not name sub-types; ExportApp (ADMIN_READ) and mutations (DATA_WRITE) depend on sub-types other than DATA_READ.	Require ADMIN_READ, DATA_READ, and DATA_WRITE.
1001	Minor	1090, 1110	Monitoring & Analytics	Product audit pages establish that logs exist but not aggregated sinks, bucket lock, or IAM separation.	Cite Cloud Logging routing and bucket-lock documentation.

#	Se ve rit y	Row ID	Category	Finding	Recommendation
102	Minor	1090, 1100	Monitoring & Analytics	Both govern keeping logs immutable and beyond administrators' reach (09.ac) but cite only 09.aa/09.ab.	Add 09.ac.
103	Minor	1140	Monitoring & Analytics	"A new tool immediately extends what every agent in the project can reach" - the vendor states a tool must be added to an agent before use.	Correct, and alert also on UpdateAgent tool changes.
104	Minor	1170	Monitoring & Analytics	"revoking the query-access client role from a channel" - roles are granted to principals; CP-9 fits version rollback poorly (CM-2(3)).	Correct the wording and control.
105	Minor	1190	Compliance & Certification	"Only ... components named in Google's HIPAA covered products list MUST be used" reads as an obligation to use them.	Restate: components not named MUST NOT be used to process PHI.
106	Minor	1210	Compliance & Certification	Neither cited page covers retrieving attestations.	Cite Compliance Reports Manager.
107	Minor	1230	Compliance & Certification	The accepted residual risks are access-control risks, but no HITRUST segment is cited.	Add 01.v.
108	Minor	1240	Compliance & Certification	PT-2 fits an AI system inventory poorly.	Replace with PM-5 or keep CM-8 alone.
109	Minor	990, 1030, 1060	Network & Perimeter Security	Perimeter rows without HIPAA while siblings 970, 980, 1000, 1020 cite it.	Apply one convention.
110	Info	n/a	Guide-wide	HITRUST CSF v11 titles were not verified against the organization's licensed v11 catalog. The 21 references in use come from the scg-generator mappings guide, which records the same limitation.	Verify against the licensed copy before publication.
111	Info	n/a	Guide-wide	HITRUST overlay: control categories with zero objective citations are 00 (Information Security Management Program), 02 (Human Resources Security), 03 (Risk Management), 04 (Security Policy), 07 (Asset Management), 08 (Physical and Environmental Security), 12 (Business Continuity Management), and 13 (Privacy Practices). 03 and 13 are the plausible omissions: the residual-risk row (1230) and the disclosure and notice rows (310, 600) fall in their scope.	Confirm the absence is intentional; consider 03.b on 1230 and a category 13 objective on the notice rows.
112	Info	n/a	Guide-wide	Reviewer checklist conflict. Checks D5 and I2 expect ID buckets per category; the generator skill (the authority) mandates flat append-only numbering with no relationship between ID and category, and IDs 1260 to 1380 sit in earlier categories by design. D4 (ascending within category) passes. Not raised as a defect. The HIPAA shape regex in check M4 also rejects valid paragraph citations such as 164.308(a)(1)(ii)(A); all 13 such citations were confirmed as real Security Rule paragraphs.	Align the reviewer checklist with the generator's numbering rule and widen the M4 pattern.

#	Se ve rit y	Row ID	Category	Finding	Recommendation
1 1 3	Inf o	30	General	Both API versions exist, but no vendor statement places v1beta or v1alpha1 under the Pre-GA terms; the status is inferred, and the cited overview pages show neither version.	Cite the REST overview pages and mark the Pre-GA status as inferred.
1 1 4	Inf o	120, 140	Identity & Access Management	The admin role includes <code>contactcenterinsights.googleapis.com/admin</code> , which strengthens 120. 140's claim that security settings govern redaction, retention, and export is not supported (see the 1120 finding).	Record both in the Notes.
1 1 5	Inf o	330	Agents & Agent Management	The agents-as-tools release note does not say GA; the page has no Preview banner. Plausible but inferred.	Mark as inferred.
1 1 6	Inf o	1260, 1280	AI Models & Model Management	The 2026-05-26 release note shows Google can upgrade models without builder action; audio agent applications cannot override the model except when used as a tool.	Add both to the Notes.
1 1 7	Inf o	360, 380	Tools & External Integrations	Tool creation and update are <code>DATA_WRITE</code> , so the inventory reconciliation depends on Data Access logging; the documented session-context parameter is the supported attribution mechanism.	Note the logging dependency and cite the mechanism.
1 1 8	Inf o	1380	Tools & External Integrations	Rated Med SHOULD NOT alongside High MUST rows 1360 and 1370 on the same surface.	Confirm the calibration is intentional.
1 1 9	Inf o	470	Tools & External Integrations	BAA coverage of Google Search grounding was not verified; if excluded, Med SHOULD NOT is too weak.	Confirm with Google.
1 2 0	Inf o	400	Tools & External Integrations	Website data stores require domain verification, which partly enforces the domains-the-organization-controls rule.	Cite it.
1 2 1	Inf o	580	Deployment & Channel Security	SecureCo is not named among third-party telephony providers; "any comparable provider" covers it.	Name it.
1 2 2	Inf o	700, 840	Conversation Analytics & Insights; Data Protection & Privacy	CX Agent Studio CMEK is managed through the Insights API, so the first logged test conversation may lock an Insights location; the Insights service-identity prerequisite and 30-day key-revocation warning are absent.	Add to the Notes.
1 2 3	Inf o	750, 780, 920, 930, 940, 1040, 1160	Conversation Analytics & Insights; Data Protection & Privacy; Network & Perimeter Security; Monitoring & Analytics	Claims that could not be verified either way on the cited pages: global-instance fallback (750), exported rows surviving deletion (780), redaction failure letting unredacted content flow (920), "dynamic variables populated per session" (930), the Pub/Sub subscriber store (940), cross-perimeter service-agent execution (1040), metrics unaffected by the logging toggle (1160).	Hedge or confirm with Google.
1 2	Inf o	790	Conversation Analytics & Insights	CX Insights Pub/Sub settings map events to topics with no payload setting; it is unclear how a notification could be configured to convey or not convey content.	Rephrase around subscriber behaviour.

#	Se ve rit y	Row ID	Category	Finding	Recommendation
4					
1 2 5	Inf o	690, 820	Agent Assist & Human Agent Support; Conversation Analytics & Insights	The two rows are substantially the same control in different sections.	Consider consolidating.
1 2 6	Inf o	830, 1320, 1350	Agent Assist & Human Agent Support; Conversation Analytics & Insights	164.308(a)(8) (Evaluation) is a weak fit; 164.308(b)(1) and 164.314(a) (BAA coverage) are closer for Pre-GA-with-PHI rows.	Consider remapping.
1 2 7	Inf o	870, 900	Data Protection & Privacy	Residency facts missing: only global Secret Manager is supported for OpenAPI tools; the BigQuery export dataset must share the agent's location. The toggle in 900 is labelled "Interaction data" in the settings page.	Add to the Notes.
1 2 8	Inf o	1170	Monitoring & Analytics	164.410 is the business associate's duty; containment could also list locking the agent and tightening allowed origins.	Clarify.
1 2 9	Inf o	1190, 1250	Compliance & Certification	No explicit cross-reference, but both depend on other controls implicitly ("a second and independent reason"; "The monthly release-note review is the trigger").	Make each self-standing.

Coverage Analysis

Categories

Expected (universal + AI/LLM platform + HIPAA overlay)	Present	Notes
## General	yes (9)	Pre-GA baseline at ID 10, High, first category.
## Identity & Access Management	yes (13)	Role family, service agent, keys, recertification, JIT. Role inheritance into CX Insights is the gap (finding on ID 730).
## Data Protection & Privacy	yes (13)	CMEK, residency, retention, deletion, training position.
## Network & Perimeter Security	yes (10)	Strong sequencing; restricted-service list incomplete (ID 970) and native egress allowlist unused (ID 1000).
## Monitoring & Analytics	yes (11)	Coverage present; log-type accuracy is the weakness (IDs 150, 570, 1050, 1070, 1080).
## AI Models & Model Management	yes (4)	Allowlist, Preview prohibition, override, launch-stage source.
## Agents & Agent Management	yes (12)	Guardrails, evaluation, delegation, human authority.

Expected (universal + AI/LLM platform + HIPAA overlay)	Present	Notes
## Tool / Connector Use	yes, as ## Tools & External Integrations (21)	The guide's largest category.
## Search & Grounding, ## Data Input & File Handling	folded into Tools	Data store, File search, and ingestion rows (390, 400, 1340, 1360 to 1380). Adequate.
## Prompt & Output Safety, ## Content Generation	folded into Agents and Agent Assist	Guardrails (230 to 260) and output rows (640 to 670). Adequate.
## Personalization & User Experience	n/a	No per-user memory surface.
## Compliance & Certification	yes (8)	BAA, covered products, attestations, residual risk.
HIPAA overlay rows	yes	BAA (1180), minimum necessary (164.502(b) on 20+ rows), six-year audit retention (1100, basis paraphrase flagged), training (90), breach notification (1170), de-identification (cited on redaction rows, fit flagged).

STRIDE Coverage (from infosec-architect/threat-modeling)

STRIDE	Addressed ?	Row(s)	Notes
Spoofing	yes	100, 110, 160, 180, 200, 510, 520, 530, 540, 1330	Member authentication design at 530 needs rework (tools.execute exposure).
Tampering	yes	450, 460, 640, 650, 670, 1110, 1330	Audit-log integrity at 1110 present.
Repudiation	partial	1070 to 1130, 1310	Rows exist, but wrong log types at 150, 570, 1050, and 1080 would leave deployment, export, and Insights mutations unrecorded.
Information Disclosure	yes	40+ rows	Centre of gravity; builders' inherited Insights read access (730) is the gap.
Denial of Service	yes	520, 590, 1300	Improved since 2026-09-04; 1300's per-deployment caps are not implementable.
Elevation of Privilege	partial	120 to 220, 490	Separation of duties and JIT present; tools.execute inherited through the client role is not addressed (160, 530).

Identity Governance Domains (from infosec-architect/identity-governance)

Domain	Addressed ?	Row(s)	Notes
Identification	yes	100, 160, 170, 200, 1310	1310's premise that one identity serves every tool call is overstated.
Authentication	yes	100, 110, 180, 200, 510, 530, 540	530 and 540 conflict.

Domain	Addressed ?	Row(s)	Notes
Authorization & Delegation	partial	330, 350, 380, 410, 730	Role inheritance (CES roles into Insights; client role into editors) is undocumented in the guide.
Lifecycle	yes	120, 130, 190, 210, 490	Recertification present.
Auditability	partial	1070 to 1150	Sub-type and log-type errors (see Repudiation).
Trust Boundaries	partial	350, 970 to 1060, 1360 to 1380	Agent Assist API outside the perimeter list (970); RAG Engine boundary now covered.
Agent identity and delegation (agent-bearing healthcare overlay)	yes	170, 330, 1310, 1330	Present, so not a Blocker; accuracy findings on 330 and 1310.

Defense in depth, least privilege, assume breach, auditability

Exfiltration controls sit at three layers, as the skill expects: perimeter (970 to 1060), identity (160, 170, 380), and data (620, 720, 920). The perimeter layer is weakened by the missing Agent Assist API and the unused egress allowlist. Least privilege is stated well for direct grants but not for inherited ones. Assume-breach controls (1110 log protection, 1170 incident response, 1310 attribution) are present. Auditability of the controls themselves (1060, 1120, 1140) is present, but 1120 watches the wrong resource for logging and redaction changes.

Authoritative-source Verification Log

Every distinct reference URL was fetched on 2026-09-23 (HTTP status and page title below; no redirects). The three row reviewers also fetched each row's references, stripped the HTML, and checked quoted text verbatim, and they consulted these additional authoritative pages not cited by the guide: CX Agent Studio settings, SecuritySettings REST, traffic-split, quotas, system tool, agent-as-tool, Salesforce/ServiceNow/Jira tools, Agent Assist KA filters, Smart Reply, AI coach, live A2A translation, CX Insights Pub/Sub and Google Sheets integration, VPC Service Controls supported products, Access Approval and Access Transparency supported services, eCFR 45 CFR 164.316, Dialogflow CX overview, and the MITRE ATLAS data file. Claims behind findings on IDs 150, 530, 570, 630, 730, 910, 960, 970, 1000, 1050, 1080, and 1200 were re-verified against the live pages before inclusion.

NIST SP 800-53: all 71 distinct identifiers checked programmatically against the Rev. 5 OSCAL catalog (usnistgov/oscal-content). None fabricated, none withdrawn; titles match (SC-7(5) differs only by an ASCII hyphen for the catalog's em dash, required by the guide's ASCII rule). HIPAA: every cited section is a real Security, Privacy, or Breach Notification Rule provision; fit findings are in the table. HITRUST CSF v11: every reference is in dotted notation within categories 00 to 13 and ordered after NIST; **titles were not verified against the licensed v11 catalog**. MITRE ATLAS: all four technique identifiers verified against the ATLAS data file.

URL	HT TP	Page title	Cited on rows (H = Risk High)
https://cloud.google.com/security/compliance/hipaa	200	https://cloud.google.com/security/compliance/hipaa	HIPAA Compliance on Google Cloud
https://cloud.google.com/terms/hipaa-baa	200	https://cloud.google.com/terms/hipaa-baa	GCP HIPAA BAA
https://cloud.google.com/terms/service-terms	200	https://cloud.google.com/terms/service-terms	Service Specific Terms
https://docs.cloud.google.com/gemini-enterprise-agent-platform/build/rag-engine/rag-overview	200	https://docs.cloud.google.com/gemini-enterprise-agent-platform/build/rag-engine/rag-overview	RAG Engine on Gemini Enterprise Agent Platform overview
https://docs.cloud.google.com/gemini-enterprise-cx	200	https://docs.cloud.google.com/gemini-enterprise-cx	Gemini Enterprise for CX

URL	HT TP	Page title	Cited on rows (H = Risk High)
https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist	200	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist	Agent Assist documentation
https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/cmek	200	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/cmek	Customer-managed encryption keys (CMEK)
https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/data-redaction-retention	200	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/data-redaction-retention	Data redaction and retention
https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/gemini-transcribe-live	200	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/gemini-transcribe-live	Gemini transcribe live
https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/regionalization	200	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/regionalization	Regionalization and data residency
https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/release-notes	200	https://docs.cloud.google.com/gemini-enterprise-cx/agent-assist/release-notes	Agent Assist release notes
https://docs.cloud.google.com/gemini-enterprise-cx/commerce-agents	200	https://docs.cloud.google.com/gemini-enterprise-cx/commerce-agents	Commerce agents
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio	CX Agent Studio
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/access-control	Access control with IAM
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/agent	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/agent	Agents
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/audit-logging	Audit Logging
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/cmek	Customer-managed encryption keys (CMEK)
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/conversation-history	Conversation history
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy	Deploy agent applications
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/deploy/web-widget	Web widget
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/guardrail	Guardrails
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/python	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/python	Python runtime reference
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/region	Regionalization and data residency
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/reference/rest/v1/projects.locations.apps.tools	REST Resource: projects.locations.apps.tools
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/resources/release-notes	CX Agent Studio release notes

URL	HT TP	Page title	Cited on rows (H = Risk High)
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool	Tools
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/cloud-storage-data-store	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/cloud-storage-data-store	Cloud storage data store tool
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/connector	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/connector	Integration Connector tools
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/data-store	Data store tools
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/file	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/file	File search tools
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/function	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/function	Client function tools
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/mcp	MCP tools
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/open-api	OpenAPI tools
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/python	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/python	Python code tools
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/website-data-store	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/tool/website-data-store	Website data store tools
https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls	200	https://docs.cloud.google.com/gemini-enterprise-cx/cx-agent-studio/vpc-service-controls	Configure VPC Service Controls for CX Agent Studio
https://docs.cloud.google.com/gemini-enterprise-cx/insights	200	https://docs.cloud.google.com/gemini-enterprise-cx/insights	Customer Experience Insights
https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging	200	https://docs.cloud.google.com/gemini-enterprise-cx/insights/audit-logging	Customer Experience Insights audit logging
https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control	200	https://docs.cloud.google.com/gemini-enterprise-cx/insights/best-practices-for-fine-grained-access-control	Best practices for fine-grained access control
https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek	200	https://docs.cloud.google.com/gemini-enterprise-cx/insights/cmek	Customer-managed encryption keys (CMEK)
https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations	200	https://docs.cloud.google.com/gemini-enterprise-cx/insights/common-integrations	Integrate conversation data
https://docs.cloud.google.com/gemini-enterprise-cx/insights/datasets	200	https://docs.cloud.google.com/gemini-enterprise-cx/insights/datasets	Customer Experience Insights datasets
https://docs.cloud.google.com/gemini-enterprise-cx/insights/qai-basics	200	https://docs.cloud.google.com/gemini-enterprise-cx/insights/qai-basics	Quality AI basics
https://docs.cloud.google.com/gemini-enterprise-cx/insights/regionalization	200	https://docs.cloud.google.com/gemini-enterprise-cx/insights/regionalization	Regionalization

URL	HT TP	Page title	Cited on rows (H = Risk High)
https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes	200	https://docs.cloud.google.com/gemini-enterprise-cx/insights/release-notes	Customer Experience Insights release notes
https://docs.cloud.google.com/gemini-enterprise-cx/insights/ttl	200	https://docs.cloud.google.com/gemini-enterprise-cx/insights/ttl	Set a TTL (time-to-live) on conversation data

Top-3 Risks

1. **Audit alerts that would never fire (IDs 150, 570, 1050, 1070, 1080).** The guide places deployment changes, traffic-split changes, agent export, and most CX Insights mutations in Admin Activity logs or in DATA_READ. Google records them as DATA_WRITE or ADMIN_READ Data Access events, which are off unless explicitly enabled per sub-type. Implemented as written, the export of an entire agent application or a bulk deletion of conversations would leave no alertable record. The guide calls this logging the primary compensating control for the missing per-conversation boundary.
2. **Inherited access the IAM rows do not see (IDs 160, 500, 530, 730).** `ces.googleapis.com/viewer` carries `contactcenterinsights.viewer`, and every CES editor role builds on it, so every agent builder can read the whole member-conversation corpus while ID 730 records Insights access as restricted to a small named group. The client role, which includes `tools.execute`, is inherited by builders and would be held by members on the OAuth path ID 530 mandates, letting an authenticated member call tools outside the agent.
3. **A perimeter that leaves Agent Assist outside (IDs 970, 1200, 1000).** Agent Assist's API is `dialogflow.googleapis.com`, which the restricted-service list omits, and ID 1200 prohibits the Dialogflow surfaces that covered Agent Assist and CX Insights require. The product's native egress allowlist, which would enforce ID 1000, goes unused.

Sign-off Checklist

- ☒ All Blocker findings resolved (none raised)
- ☒ Pre-GA / Preview prohibition present (IDs 10, 20, 30, 40, 50, 1270, 1320, 1350)
- ☐ NIST 800-53 cited only where applicable (fit findings on 250, 300, 400, 460, 620, 720, 850, 870, 880, 890, 900, 920, 940, 1170, 1240)
- ☐ HITRUST CSF v11 cited where access control, data protection, audit, or transmission applies (missing on 50, 410, 450, 490, 500, 550, 950; titles unverified against the licensed catalog)
- ☐ HIPAA cited where PHI applies (missing on 410, 430, 450, 550, 870, 880, 950, 1040, 1360; misfits on 270, 370, 620, 720, 920, 940 and on the 164.530(j) retention rows)
- ☒ References resolve to authoritative sources (46 of 46 live; supporting-page gaps on 130, 180, 640 to 670, 990)
- ☐ Defense-in-depth verified (perimeter layer incomplete, ID 970)
- ☐ Identity-governance domains all addressed (role inheritance, IDs 160, 530, 730)
- ☐ Risk/Cost calibration consistent across similar rows (40, 630/710, 800, 1060/1120, 1080/1150, 1020/1040/1050, 1320/1350, 850/860)

Resolutions

The owner approved applying the fixes on 2026-09-23. Each finding below is keyed to the numbered Findings table. Replacement cell text was drafted by the three reviewers for their own rows as patch files, then merged, validated, and read by the lead before the CSV was written; nothing edited the CSV directly. Details are in

notes/SCG-remediation-2026-09-23.md, and the row-level trace is in _src/geminiCustomerExperienceGuidance-diff-map-2026-09-23.csv.

#	Severity	Row ID	Resolution
1	Major	150	Applied on 150.
2	Major	570	Applied on 570.
3	Major	1050	Applied on 1050.
4	Major	1080	Applied on 1080.
5	Major	160	Applied on 160.
6	Major	530	Applied on 530.
7	Major	530, 540	Applied on 530, 540.
8	Major	500	Applied on 500.
9	Major	730	Applied on 730.
10	Major	970	Applied on 970.
11	Major	1200	Applied on 1200.
12	Major	1000	Applied on 1000.
13	Major	1120	Applied on 1120.
14	Major	1310	Applied on 1310.
15	Major	10	Applied on 10.
16	Major	20	Applied on 20.
17	Major	60	Applied on 60.
18	Major	250	Applied on 250.
19	Major	310	Applied on 310.
20	Major	300	Applied on 300.
21	Major	440	Applied on 440.
22	Major	480	Applied on 480.
23	Major	130, 180	Applied on 130, 180.
24	Major	40	Applied on 40.
25	Major	1320, 1350	Applied on 1320.
26	Major	630	Applied on 630.
27	Major	630, 710	Applied on 630, 710.
28	Major	620, 720, 920	Applied on 620, 720, 920.
29	Major	640, 650, 660, 670	Applied on 640, 650, 660, 670.

#	Severity	Row ID	Resolution
30	Major	660	Applied on 660.
31	Major	680	Applied on 680.
32	Major	740	Applied on 740.
33	Major	800	Applied on 800.
34	Major	590	Applied on 590.
35	Major	600	Partly applied: 164.520 dropped and the claim scoped to enabled recording; the state recording-consent statute is not cited because no allowed reference domain carries state law. Counsel to confirm (workstream).
36	Major	910	Applied on 910.
37	Major	960	Applied on 960.
38	Major	1100	Applied on 1100.
39	Major	940	Applied on 940.
40	Major	1060, 1120	Applied on 1060, 1120.
41	Major	1080, 1150	Applied on 1150.
42	Major	1020, 1040, 1050	Applied by alignment rather than merger: IDs 1040 and 1050 raised to High; rows are not merged because IDs are published.
43	Major	990	Applied on 990.
44	Major	50, 490	Applied on 50, 490.
45	Major	410, 450	Applied on 410, 450.
46	Major	500, 550	Applied on 500, 550.
47	Major	950	Applied on 950.
48	Major	430, 870, 880, 1040, 1360	Applied on 430, 870, 880, 1040, 1360.
49	Major	270, 370	Applied on 270, 370.
50	Minor	500	Applied on 500.
51	Minor	770	Applied on 770.
52	Minor	1350	Applied on 1350.
53	Minor	390	Applied on 390.
54	Minor	1270	Applied on 1270.
55	Minor	70	Applied on 70.
56	Minor	110	Applied on 110.
57	Minor	260	Applied on 260.
58	Minor	330, 350, 420, 90	Applied on 90, 330, 350, 420.
59	Minor	120, 340, 670	Applied on 120, 340, 670.

#	Severity	Row ID	Resolution
60	Minor	320	Applied on 320.
61	Minor	240	Applied on 240.
62	Minor	250, 400	Applied on 250, 400.
63	Minor	460	Applied on 460.
64	Minor	100	Applied on 100.
65	Minor	170, 350	Applied on 170, 350.
66	Minor	170, 300, 330, 350, 380, 400, 410, 420, 450, 490, 1310, 1330	Applied on 170, 300, 330, 350, 380, 400, 410, 420, 450, 490, 1310, 1330.
67	Minor	100, 110, 200	Applied on 100, 110, 200.
68	Minor	150	Applied on 150.
69	Minor	540	Applied on 540.
70	Minor	550	Applied on 550.
71	Minor	560	Applied on 560.
72	Minor	1300	Applied on 1300.
73	Minor	610, 700	Applied on 610, 700.
74	Minor	620	Applied on 620.
75	Minor	640	Applied on 640.
76	Minor	640, 670	Applied on 640, 670.
77	Minor	640, 650, 670	Applied on 640, 650, 670.
78	Minor	670	Applied on 670.
79	Minor	690	Applied on 690.
80	Minor	710	Applied on 710.
81	Minor	720	Applied on 720.
82	Minor	760	Applied on 760.
83	Minor	1320	Applied on 1320.
84	Minor	630, 710, 760, 780, 800, 830, 1100	Applied on 630, 710, 760, 780, 800, 830, 1100.
85	Minor	840	Applied on 840.
86	Minor	850	Applied on 850.
87	Minor	860	Applied on 860.
88	Minor	870, 880	Applied on 870, 880.
89	Minor	890	Applied on 890.

#	Severity	Row ID	Resolution
90	Minor	900	Applied on 900.
91	Minor	930	Applied on 930.
92	Minor	960	Applied on 960.
93	Minor	970	Applied on 970.
94	Minor	980, 1120	Applied on 980, 1120.
95	Minor	990	Applied on 990.
96	Minor	1000	Applied on 1000.
97	Minor	1010	Applied on 1010.
98	Minor	1030	Applied on 1030.
99	Minor	1060	Applied on 1060.
100	Minor	1070, 1080	Applied on 1070, 1080.
101	Minor	1090, 1110	Applied on 1090, 1110.
102	Minor	1090, 1100	Applied on 1090, 1100.
103	Minor	1140	Applied on 1140.
104	Minor	1170	Applied on 1170.
105	Minor	1190	Applied on 1190.
106	Minor	1210	Applied with a substitute source: Compliance Reports Manager renders client-side, so the SOC 2 page, which names it, is cited.
107	Minor	1230	Applied on 1230.
108	Minor	1240	Applied on 1240.
109	Minor	990, 1030, 1060	Applied on 990, 1030, 1060.
110	Info	n/a	No CSV change: recorded for the program (HITRUST catalog verification, category coverage, reviewer checklist alignment).
111	Info	n/a	No CSV change: recorded for the program (HITRUST catalog verification, category coverage, reviewer checklist alignment).

#	Severity	Row ID	Resolution
112	Info	n/a	No CSV change: recorded for the program (HITRUST catalog verification, category coverage, reviewer checklist alignment).
113	Info	30	Applied on 30.
114	Info	120, 140	Applied on 120, 140.
115	Info	330	Applied on 330.
116	Info	1260, 1280	Applied on 1260, 1280.
117	Info	360, 380	Applied on 360, 380.
118	Info	1380	Not applied - owner decision. Whether ID 1380 should be MUST NOT is left open in the workstream.
119	Info	470	Applied on 470.
120	Info	400	Applied on 400.
121	Info	580	Applied on 580.
122	Info	700, 840	Applied on 700, 840.
123	Info	750, 780, 920, 930, 940, 1040, 1160	Applied on 750, 780, 920, 930, 940, 1040, 1160.
124	Info	790	Applied on 790.
125	Info	690, 820	Applied without merging: 690 now covers the Agent Assist data flow and 820 Quality AI in CX Insights; one approval satisfies both.
126	Info	830, 1320, 1350	Applied on 830, 1320, 1350.
127	Info	870, 900	Applied on 870, 900.
128	Info	1170	Applied on 1170.
129	Info	1190, 1250	Applied on 1190, 1250.